ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Siemens Desigo PXC Automation Station (BAS controller) · Component type: **Embedded Device (EDR) - BAS/BACnet controller** · Target SL = SL 3

Where to work	Engineer with **ABT Site / ABT Pro** (Automation Building Tool) or the Desigo CC engineering; controller **web/user accounts** (PXC..D web), **BACnet/SC** where supported, firmware via ABT/HQ; management via Desigo CC.
Interfaces / ports	**BACnet/IP** (47808), BACnet/SC (TLS) on newer FW, embedded **web server** (80/443) on -D models, MS/TP field bus, time sync. Field automation station.
Notes	EDR (embedded BAS controller) — Siemens Desigo PXC automation station. Native crypto depends on model/firmware; where BACnet/SC or web-TLS is unavailable, security relies on **network segmentation + a secure gateway** (compensating) — record which applies.
How to read	Read-only: review ABT/Desigo CC config + controller web settings. Native how-to + external-tool validation + pass. Scans authorized; fuzz/exploit only in an isolated environment with written authorization.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the **ABT Site / ABT Pro (Automation Building Tool)** project backup for the PXC (or the Desigo CC engineering export), the controller web/user accounts, the BACnet (+ BACnet/SC where supported) + panel config, firmware rev, and the controller logs.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	Confirm controller web/management access requires authentication (controller user accounts; management centralized in Desigo CC); disable anonymous/guest; where the controller cannot authenticate, front it with an authenticating gateway (compensating). **Ext. tools:** Controller web / ABT account review; attempt anonymous (isolated).	Access authenticated (native or via gateway); no anonymous use.	
SR/CR 1.2	Software process / device identification	Confirm a unique BACnet device instance and IP/name per controller; management and field partners are identified/bound; BACnet/SC binds by certificate where used. **Ext. tools:** BACnet device-ID inventory; ABT config.	Unique device identity; partners identified.	
SR/CR 1.3	Account management	Manage controller/management accounts (create/modify/disable), remove defaults, least-privilege roles (monitor vs operate vs engineer); prefer central management in Desigo CC. **Ext. tools:** Account review (controller / Desigo CC).	Accounts managed; least-privilege; defaults changed.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers and unique device identity (BACnet instance, IP, name); no reuse across the BAS. **Ext. tools:** User + BACnet inventory.	Unique user and device identifiers; no reuse.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.5	Authenticator management	Enforce strong controller/management passwords; change all factory defaults; manage lifecycle centrally in Desigo CC where possible. **Ext. tools:** Password-policy / default-credential check.	Strong, managed authenticators; no defaults.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	PKI certificates	Where **BACnet/SC** or web-TLS is supported, confirm CA-issued, valid certificates (not default self-signed); manage the trust list. Where unsupported, record the compensating secure-gateway control. **Ext. tools:** openssl (443 / BACnet/SC); cert review.	CA-issued certs where supported; else compensating gateway recorded.	
SR/CR 1.9	Strength of public key auth	Where TLS/BACnet/SC is used, confirm strong ciphers/keys; no weak/expired certs. Legacy models without TLS rely on the compensating gateway. **Ext. tools:** testssl.sh (if web-TLS); BACnet/SC policy review.	Strong crypto where supported; compensating control otherwise.	
SR/CR 1.10	Authenticator feedback	Confirm the controller web / management logon masks password entry (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Confirm repeated failed logins are throttled/locked (controller web / Desigo CC) and recorded; where unsupported, the gateway/IDS detects brute force. **Ext. tools:** Lockout test (isolated); SIEM/IDS failed-auth events.	Failed logins throttled/locked and logged (native or compensating).	
SR/CR 1.12	System use notification	No native banner on the controller; enforce the approved use notice at the engineering workstation / Desigo CC and gateway (compensating). **Ext. tools:** EWS / Desigo CC banner review.	Approved use notice at EWS/management (compensating at controller).	Compensating.
SR 1.13	Access via untrusted networks	Confirm BACnet/IP and web are reachable only within the BAS zone behind a firewall / secure gateway; remote via VPN; deny from untrusted networks. **Ext. tools:** Nmap (untrusted side); firewall/gateway rule review.	Access from untrusted networks denied/brokered; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm roles enforce monitor vs operate vs engineer; program/config download requires the engineering credential; unauthorized commands (override) denied. **Ext. tools:** Role review; attempt unauthorized command (isolated).	Least-privilege enforced; config change requires authorization.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control the engineering laptop and any service/USB port; ABT project files controlled; removable-media policy on the EWS. **Ext. tools:** Physical inspection; EWS media policy.	Engineering media/service ports controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code on the controller; confirm only the compiled control application and vendor web content run; no untrusted code path. **Ext. tools:** ABT/web content review.	Only the trusted control application runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm web/management sessions time out on inactivity and require re-authentication. **Ext. tools:** Web/Desigo CC timeout config.	Sessions lock/expire on inactivity; re-auth required.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.6	Remote session termination	Confirm web/management sessions can be terminated and idle sessions close; the access list limits reconnection. **Ext. tools:** Session status review.	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent web/management sessions to the controller are bounded and monitored. **Ext. tools:** Session/connection review.	Concurrent sessions limited/monitored.	
SR/CR 2.8	Auditable events	Confirm security-relevant events (logon, config change) are logged locally and/or in Desigo CC and forwarded (Syslog) to the SIEM; actions attributable to a user. **Ext. tools:** Event log / Desigo CC audit; SIEM forwarding.	Security events logged, forwarded, and attributable.	
SR/CR 2.9	Audit storage capacity	The controller log is finite; rely on Desigo CC/SIEM for retention; confirm sizing and threshold alerting. **Ext. tools:** Desigo CC / SIEM retention review.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/Desigo CC alerts if controller event forwarding fails; events not silently lost. **Ext. tools:** SIEM/Desigo CC forwarding-gap alert.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	Confirm the controller time is synced (BACnet time sync / NTP) so event timestamps are accurate and correlate across the BAS. **Ext. tools:** Time-sync config review.	Reliable, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: service/USB/console and the field-bus ports in a locked panel; disable unused web/diagnostics; tamper-evident enclosure. **Ext. tools:** Physical inspection; disabled-service review.	Physical/diagnostic interfaces controlled; enclosure sealed.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Use **BACnet/SC** (TLS) where supported for controller-to-management/field integrity+confidentiality; where only BACnet/IP is available, contain cleartext within the segmented BAS zone (compensating). **Ext. tools:** Wireshark (BACnet/SC vs cleartext BACnet/IP).	BACnet/SC where supported; cleartext BACnet contained to the zone.	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only Siemens-signed firmware and the compiled application run; the controller has no general code-execution path; tampered logic prevented/detected. **Ext. tools:** ABT/firmware review; signature check.	Only signed firmware/authorized logic runs; component protected.	EDR-specific.
SR/CR 3.3	Security functionality verification	After change, re-verify accounts, disabled services, BACnet/SC, certificates, and segmentation against the baseline; confirm no drift. **Ext. tools:** Config compare; Nmap (services off).	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Confirm application/logic integrity: project protection in ABT/Desigo CC and change detection so unauthorized changes are prevented/detected; controlled download. **Ext. tools:** Project-protection review; online-vs-offline compare.	Application integrity protected; unauthorized change prevented/detected.	
SR/CR 3.5	Input validation	Confirm the controller tolerates malformed BACnet/web frames without faulting. **ISOLATED only:** fuzz BACnet/IP and web on a representative unit and watch control/comms health. **Ext. tools:** BACnet fuzzer / traffic generator (ISOLATED); Wireshark.	No crash or loss of control on malformed input.	Do NOT fuzz production.
SR/CR 3.6	Deterministic output	Verify configured fail-safe behavior for controlled outputs (fallback/last-known/safe value on comm loss or fault) so plant equipment assumes a defined safe state. **Ext. tools:** ABT (output fallback / fail-safe config review).	Outputs go to a defined/fail-safe state on fault or comm loss.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.7	Error handling	Confirm graceful fault handling (diagnostics, watchdog, defined restart) without loss of control or info leakage. **Ext. tools:** Controller diagnostics review.	Graceful fault handling; no unsafe state or info leak.	
SR/CR 3.8	Session integrity	Where BACnet/SC / web-TLS is used, sessions are integrity-protected against replay/hijack; legacy sessions contained by the zone. **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected where supported; else contained.	
SR/CR 3.9	Protection of audit information	Protect event transport and the Desigo CC/SIEM store; restrict who can read/clear controller logs. **Ext. tools:** SIEM/Desigo CC access review.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware only with **Siemens-signed** firmware via ABT/HQ; the controller validates the image; plan controlled updates with rollback to a prior signed revision. **Ext. tools:** ABT firmware update / signature; Siemens ProductCERT advisory check.	Signed firmware updates only, with a controlled update + rollback path.	EDR-specific.
EDR 3.11	Physical tamper resistance/detection	Keep the controller in a locked, sealed panel; service/USB and field ports controlled; log config/firmware changes as tamper evidence. **Ext. tools:** Physical inspection; event-log review.	Enclosure locked/sealed; interfaces controlled; changes logged.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	The controller accepts only Siemens-signed firmware (supplier root of trust); confirm the signing chain is intact and unsigned/altered firmware is rejected at load. **Ext. tools:** ABT (firmware signature verify); attempt unsigned image (isolated) -> rejected.	Supplier signing root intact; unsigned/altered firmware rejected.	EDR-specific.
EDR 3.13	Provisioning asset-owner roots of trust	Where BACnet/SC / web-TLS is used, confirm the asset owner can provision/manage its own certificates and trust list; else record the compensating gateway. **Ext. tools:** Certificate/trust-list review.	Asset-owner cert provisioning where supported, or compensating recorded.	EDR-specific.
EDR 3.14	Integrity of the boot process	Confirm the controller validates signed-firmware integrity before execution; no unsigned/tampered firmware runs. Capture firmware version/status. **Ext. tools:** ABT (firmware version/signature status).	Firmware integrity validated before execution; only signed firmware boots.	EDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/reuse, reset the controller to factory defaults and clear the application, accounts, certificates, and any stored data so configuration is not recoverable. **Ext. tools:** Factory reset; verify config cleared.	Sensitive config purged on decommission or reuse.	
SR/CR 4.3	Use of cryptography	Where supported, confirm modern crypto for BACnet/SC / web-TLS (TLS 1.2/1.3); disable legacy unauthenticated web; where unsupported, rely on the segmented zone + secure gateway. **Ext. tools:** testssl.sh (web); BACnet/SC policy review.	Modern crypto where supported; compensating control otherwise.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Place the BAS/BACnet field network in a **Protected Zone** with real Zone Boundary Protection — a **firewall / secure gateway is required; a separate VLAN alone does NOT meet ZBP** (per Siemens BAS cybersecurity guidance). Only required BACnet/management flows cross; remote via VPN; no flat convergence with IT. **Ext. tools:** Nmap by zone; firewall/gateway rule review (confirm ZBP, not just VLAN).	Controller in a firewalled Protected Zone (VLAN alone insufficient); only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General Purpose Person-to-Person Communication Restrictions	**N/A.** Embedded device has no general-purpose person-to-person communications (email/IM/web).	N/A - justification recorded (not assessed as a control).	N/A
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm events are readable/exportable (controller/Desigo CC) and forwarded to the SIEM; the BAS zone is monitored (passive IDS). **Ext. tools:** Syslog/SIEM forwarding; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm DoS resilience: the controller and BAS gateway limit connection/BACnet flood impact so control continues; only required services exposed. **Ext. tools:** Traffic generator (ISOLATED); Nmap.	Resources bounded; control continues under load.	
SR/CR 7.2	Resource management	Confirm the controller bounds resource use (connection limits, cycle monitoring) so a single service cannot starve control. **Ext. tools:** Controller resource/cycle review.	Resources bounded; no exhaustion-based loss of control.	
SR/CR 7.3	Control system backup	Confirm the ABT/Desigo CC project and controller configuration are backed up (versioned, offline) and restore is tested for a known-good rebuild. **Ext. tools:** Backup review; restore test (lab).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.6	Network & security configuration settings	Confirm hardening: disable the embedded web if unused (or HTTPS-only), disable unused BACnet services/foreign-device registration, restrict ports per baseline. **Ext. tools:** Service/BACnet config review; Nmap.	Least functionality; unused services disabled per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the controller (model, firmware, BACnet instance) is inventoried so vulnerabilities track against Siemens ProductCERT advisories. **Ext. tools:** ReadOnlyEnum; ABT/Desigo CC inventory.	Accurate component/firmware inventory maintained.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
ABT Site/Pro / Desigo CC	Native config & account review (all FRs)	Read controller accounts, services, BACnet/SC, certificates, firmware, and output fail-safe; compare to baseline.	Read/authorized copy.
Nmap / ReadOnlyEnum	Exposed-service & zone enumeration (1.13, 5.x, 7.6, 7.8)	Enumerate BACnet/IP 47808, web 80/443 from each zone; confirm only required services reachable.	Read-only; authorized.
Wireshark	Comms integrity review (3.1, 3.8)	Confirm BACnet/SC channels are encrypted; cleartext BACnet/IP is contained to the segmented zone.	Passive capture.
BACnet fuzzer / traffic generator	Input validation & DoS resilience (3.5, 7.1)	Malformed-frame / high-rate BACnet/web testing while watching control/comms health.	ISOLATED/non-production; written authorization.
testssl.sh	Web-TLS / BACnet/SC strength (1.8, 1.9, 4.3)	Where web-TLS/BACnet-SC exists, check TLS versions/ciphers; else record the compensating gateway.	Non-intrusive.
Syslog listener + SIEM	Event forwarding & monitoring (2.8-2.10, 6.x)	Confirm controller/Desigo CC events reach the SIEM; trigger a test event.	Coordinate with SIEM team.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.